Guideline on ICT Security for Banks & NBFIs (Part 2)

Chapter 11 (v3) and Chapter 13,14 (v4)

Presented by: Team 06



Team-06



Takia Farhin
210042117



Labibah Hoque
210042121



Antara Arifa Mullick
210042132



Tahsin Islam
210042137



Niaz Rahman
210042159

ICT and the Banking Industry

The modern banking industry relies heavily on ICT to manage financial operations and provide services to customers.



Banks use ICT systems for:

- Processing financial transactions
- Managing customer accounts
- Online and mobile banking services
- Payment processing systems
- ATM and POS transactions

ICT has made banking more efficient and accessible, but also more vulnerable to cyber threats.

Digital Transformation in Banking

- Internet banking platforms
- Mobile banking applications
- Contactless payment systems
- Digital wallets
- Real-time payment systems
- Artificial intelligence in fraud detection

Digital transformation integrates advanced technologies into banking to improve efficiency, customer experience, and financial inclusion, but it also requires strong cybersecurity measures.

Importance of ICT Security in Financial Institutions

- ICT security is important for banks because they manage sensitive customer data, financial transactions, and confidential information.
- It helps protect banking systems from cyber attacks, unauthorized access, and threats to data confidentiality and integrity.
- Strong ICT security also supports system reliability and availability while reducing financial, legal, and reputational risks.



Bangladesh Bank ICT Security Guidelines

Bangladesh Bank introduced the ICT Security Guidelines to ensure that banks and financial institutions adopt appropriate security measures for protecting their ICT infrastructure.

The guideline provides a framework for:

- ICT governance and management
- Risk assessment and risk management
- Infrastructure security
- Cyber incident response
- Secure digital banking services

These guidelines define the minimum security requirements that financial institutions must follow.



Evolution of ICT Security Guidelines





The ICT Security Guideline has been updated over time to address technological changes and emerging cyber threats.
Major versions include:

- Version 1 – 2005
- Version 2 – 2010
- Version 3 – 2015
- Version 4 – 2023

Version 4 introduces enhanced cybersecurity governance, cloud security management, and emerging technology management.

Legal Framework Behind the Guidelines

Law	Relevance
• Bank Companies Act, 1991 • ICT Act, 2006 (amended 2013) • Digital Security Act, 2018 • Money Laundering Prevention Act, 2012 • Payment and Settlement Systems Regulations, 2014 • Bangladesh Bank Order, 1972	• Core banking operations & supervision • Cyber crime, digital evidence, electronic transactions • Cybersecurity offenses, data protection • AML compliance in digital banking • Regulates payment systems & ADCs • Authority of BB to issue binding guidelines

Customer Education — Why It Matters

Core Argument:

- In digital/self-service banking, the customer is the last line of defense
- Fraudsters exploit customer ignorance through phishing, social engineering, SIM swapping, card skimming
- No matter how strong the bank's systems are, an uninformed customer can be the weakest link
- Bangladesh Bank (v3, Ch. 11) made customer education a mandatory regulatory requirement



Key Quote from Guideline

"The best defense against frauds is awareness of the customer."

Awareness Program — Core Objectives



- **Inform** — Provide specific info about fraud risk trends and controls to those who need it
- **Identify** — Help consumers spot areas vulnerable to fraud and understand their responsibilities
- **Motivate** — Encourage individuals to follow recommended guidelines and practices
- **Culture** — Build a stronger culture of security with better understanding and commitment
- **Minimize** — Reduce the number and extent of incidents, cutting direct fraud losses and investigation costs

Awareness Delivery Channels

Physical Collateral	Digital Channels	Mass Media
• Leaflets • Account statements • Opening kits • ATM receipts • Screensavers • DVDs	• SMS texts • Newsletters • Online modules • Phone hold message	• TV/Radio • Print ads • Billboards • Social media • Online shop ads

Program Planning Requirements

STEP 1: Identify Needs
Know your audience before designing anything

STEP 2: Budget & Priorities
Secure funding, set what matters most

STEP 3: Work Plan
Activities, timelines, milestones, resources

Program Planning Requirements

STEP 4: Right Message, Right Audience
Match content to channel to audience segment

STEP 5: Feedback Mechanism
Measure, evaluate, improve continuously

STEP 6: Multi-Channel Approach
Never rely on just one channel

What Changed in Customer Education

2015

Standalone Chapter 11

General Awareness

Physical + Digital Collaterals

No Fraud risk trend focus

8 years of Digital Evolution

2023

Integrated Section 13.6

Outcome Focused

Targeted , Fraud-driven Culture

Explicit Fraud trend education

Overview of the Training Framework



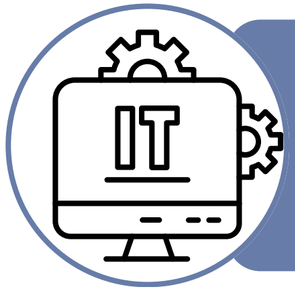
Management Training



Employee Training



General User Awareness



IT Personnel Education & Training



Training of Trainers



Customer Education

Management Training

ICT Governance

Existing IT Infrastructure & Security Measures

5 Mandatory Areas

Role of IT in Business

ICT Security Policies, Activities & Guidelines

Responsibilities & Liabilities in Security Incidents

Employee Training — Delivery Methods

10 Approved Delivery Methods - Cost-effective & Goal Oriented

- Expert-Led Training
- On-the-Job Training
- E-learning Modules
- Conferences and Seminars
- Rotation Assignments
- Pre-employment Training
- Training Apprentices
- Continuous Assistance
- Online Training Programs
- Counseling Sessions

Employee Training — Module Types

Type	Description	Example
Technical Skills	Specialized subjects matching the job function	Network security, database admin
Managerial Skills	Skills for managing teams and functions	Risk governance, team leadership
Soft Skills	Personal attributes for effective interaction	Communication, ethics, reporting
Professional Certification	Recognized specialty certification	CISSP, CISA, CEH, CompTIA Security+

General User Awareness & Education

1. Dedicated Security Awareness and Education programs
2. Real scenario-based programs
3. Conduct Risk Management / Information Security Seminars periodically
4. Ensure adequate training for IS/ICT Audit teams

WHY SCENARIO-BASED?

People learn from stories and real examples far better than from policy documents. Simulated phishing attacks, mock social engineering attempts, and tabletop exercises are internationally proven methods.

IT Personnel Education & Training

1 **PROFESSIONAL SECURITY TRAINING** (From internationally reputed bodies)

- ISC2, CISSP, SSCP
- EXIN, CompTIA, and vendor certifications
- ISACA (CISA, CISM, CRISC)
- EC-Council (CEH, CPENT)

2 **Incentives & reward for Certification**

3 **Incident Reduction Education**

4 **Business Foundation Training**

5 **IS Audit Team Training**

Training of Trainers

Internal trainers deliver training at scale. If they are poorly trained, the entire organization suffers.



Unique Specialized Training

- Trainers must receive topic-specific training
- Training methodology for effective delivery
- Includes adult learning, presentation skills, and Q&A handling



Trainer Qualification Evaluation

- Assess qualifications before appointment
- Evaluate relevant industry experience
- Only qualified trainers should conduct training

*Aligned with **ISO 29990** and global learning service frameworks.*

Customer Education

Objectives

1. Inform customers about fraud risks, trends, and prevention methods
2. Help customers identify vulnerable situations and understand their responsibilities
3. Encourage adoption of secure practices and guidelines
4. Build a strong security culture among customers
5. Reduce fraud incidents and investigation costs

> **Notable Adition in v4**
> *Banks must regularly update awareness programs as new fraud types emerge (e.g., deepfake scams, OTP fraud, QR phishing).*

Comparative Analysis

v3 (2015) vs v4 (2018)

v3 (2015)
V4 (2018)

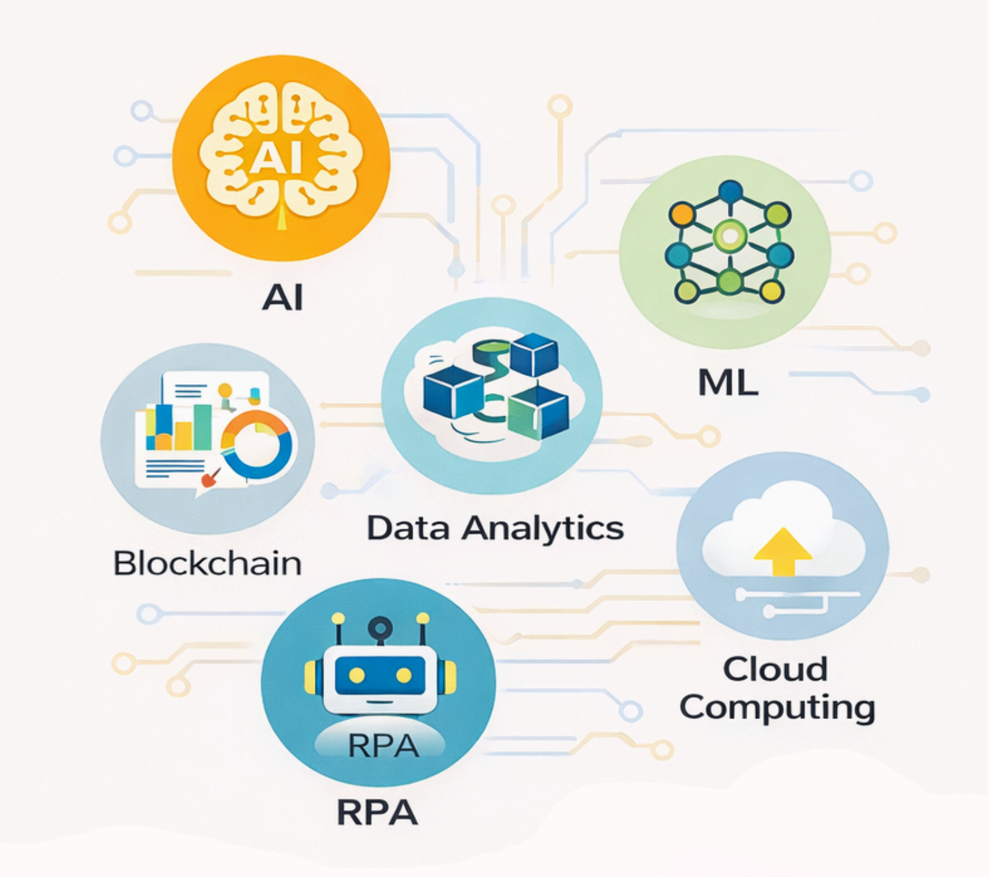
	v3 (2015)	V4 (2018)
Management Training	Not explicitly required	Mandatory
Employee Training	General awareness training	10 delivery methods
IT Certifications	Appreciated	ISC2, ISACA, EC-Council
Training of Trainers	Not mentioned	Mentioned in Section 13.5
Scenario Training	Not specified	Required
Emerging Tech	Not mentioned	Covered in Ch.14

Emerging Technology Management

Introduction

- The banking sector is undergoing a massive digital transformation
- Technologies like **AI**, **ML**, **Data Analytics**, **Blockchain**, **RPA**, and **Cloud Computing** are now mainstream in banking
- v3 (2015) had **NO chapter** on emerging technologies — **this is entirely new in v4 (2023)**

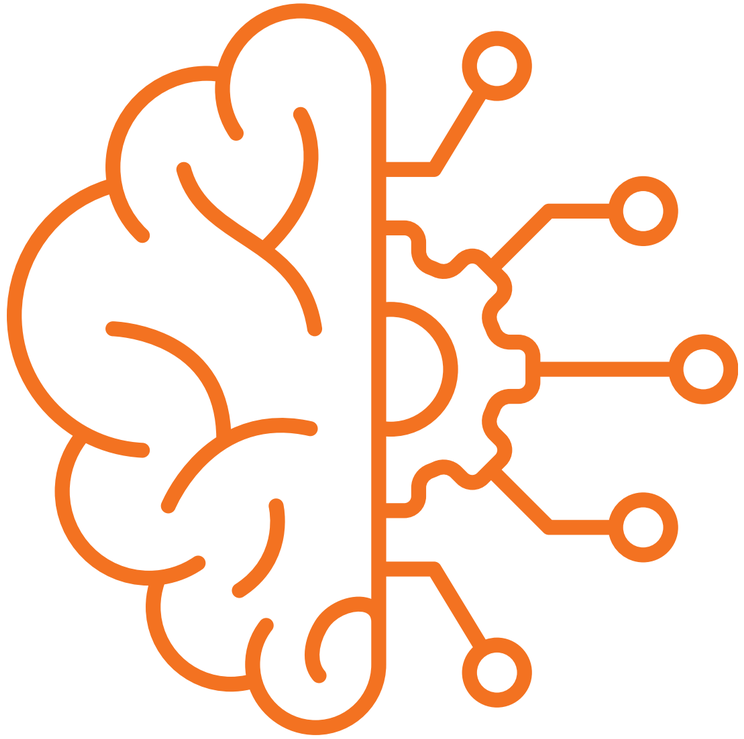
> *Embracing new technique is vital but brings new risks ...*



Artificial Intelligence in Banking

How banks use AI

- **Developing** new products based on customer preferences
- **Customer** identification and authentication (facial recognition, biometrics)
- **Chatbots** and voice bots mimicking live employees
- **Deepening** customer relationships through personalized insights and recommendations
- **Fraud detection** and credit risk scoring



Artificial Intelligence in Banking

AI Security Risks



Scripting Errors & Flawed Algorithms



Data Management Lapses



System Vulnerabilities



Bias in Training Data



Reputational & Financial Impact



Poor Human-Machine Interaction

AI Security Management Controls

Seven Mandatory Controls

1. Prevent corruption or misuse by disgruntled employees or external actors
2. Apply human judgment to detect biased or faulty system results
3. Ensure AI transparency to improve customer service
4. Maintain continuous monitoring by qualified human resources

AI Security Management Controls

Seven Mandatory Controls

5. Design systems to hide and protect Personally Identifiable Information (PII)
6. Ensure relevant staff understand AI risks and mitigation
7. Establish fallback plans for model drift, data shifts, or natural disasters

Machine Learning in Banking

Banking Applications of ML

- **Financial Forecasting** (credit risk, market risk)
- **Automation of Repetitive Tasks** (replacing or assisting human experts)
- **Facial Recognition** and **Optical Character Recognition** (OCR)
- **Fraud Pattern Detection** and **Anomaly Identification**

Machine Learning in Banking

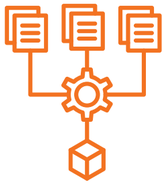
ML Security Risks



Adversarial Attacks



Poisoning Attacks



Model Inversion



Online System Manipulation



Transfer Learning Attacks



Privacy Attacks

ML Security Management Controls

Five Key Controls

1. Implement a mechanism to check internal training data for contamination
2. Perform ground-truth tests after every session; significant classification shifts indicate poisoning
3. Compress the model to create a smooth decision surface, reducing the room for attacker manipulation
4. Train the model using all possible adversarial (accusatory) examples an assailant might employ
5. Ensure that the algorithm is not biased to maintain both security and fairness

Data Analytics in Banking

What DA Enables!!!



Real-Time Insights



Customer Intelligence



Smart Sales (Upsell/Cross-sell)



AI-Driven Banking

Data Analytics in Banking

DA Security Risks



Data Tampering



Eavesdropping on data streams



Data Theft



Falsifying User Identities



Password-related threats



Unauthorized access to database



Lack of accountability in data handling

Data Analytics Security Controls

1

Analysts must understand all stages of data analytics and related tools.

2

Monitor system activities and user behavior to detect suspicious patterns.

3

Track user access and review permissions regularly.

4

Restrict and control access to sensitive files.

Data Analytics Security Controls

5

Use behavior-based permissions for adaptive access control.

6

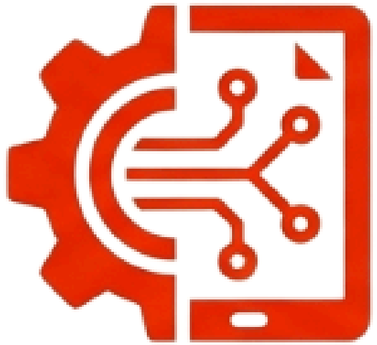
Apply data sanitization to validate and clean inputs.

7

Report analysis results clearly and understandably.

Automating the Bank with Robotic Process Automation

The Function



Allowing bots to handle repetitive, high-volume tasks entirely without human intervention, drastically improving prursinm processing processing speed and user experience.

Core Banking Use Cases

- Account opening processing
- Automated report generation
- Rapid compliance checks
- Bulk data entry

Strict Protocols for Securing Non-Human Identities

1

Total Accountability

Every single bot action must be perfectly traceable.

2

Unique Identities

Bot operators and bot identities must be strictly differentiated.

3

Restricted Access

Bots only receive the absolute minimum access necessary, preventing privilege escalation.

4

Tamper-Proof Logging

Complete, system-generated logs with absolutely zero gaps allowed.

5

Log Integrity

Essential protection of log files for post-incident investigation.

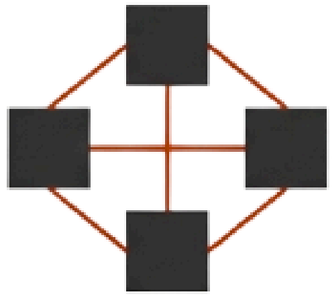
6

Script Testing

Periodic review focusing specifically on business logic vulnerabilities.

Distributed Ledger Technology / Blockchain

Strategic Value



Core Capabilities

- Decentralized transaction records
- Transparent operations
- Immutable data integrity

Cross-Industry Applications

Finance, supply chain, digital identity, healthcare, real estate.

The Threat Landscape

Apex Vulnerabilities

- ⚠ Private key compromise
- ⚠ Over 50% (majority) attacks

Secondary Vulnerabilities

- Malware vulnerability
- Wallet attacks
- Time-jacking attacks
- Race attacks
- Selfish mining
- Smart contract vulnerabilities

The Defense Protocol

1. **Define Business Process**
   Establish clear parameters for blockchain solutions and specific use cases.
2. **Execute Risk Strategy**
   Perform comprehensive risk assessment, treatment, monitoring, and review.
3. **Establish Data Governance**
   Determine data type and ownership responsibilities for data stored on the blockchain.
4. **Implement IAM**
   Define Identity Access Management specifically tailored for blockchain services.
5. **Deploy HSM**
   Establish procedures for implementing Hardware Security Modules to secure blockchain identity keys.
6. **Secure Communications**
   Protect all internal and external communications using highly secure channels.
7. **Manage Security Incidents**
   Define event management processes including preparation, detection, containment, eradication, and recovery.

What v3 Completely Missed

Technology	v3 (2015)	v4 (2023)
Artificial Intelligence	Not mentioned	Full section with 7 controls
Machine Learning	Not mentioned	Full section with 6 controls
Data Analytics	Not mentioned	Full section with 7 controls
RPA	Not mentioned	Full section with 6 controls
Blockchain/DLT	Not mentioned	Full section with 7 controls
Cloud Computing	Brief mention	Expanded in other sections
IoT Security	Not mentioned	Referenced in glossary

Lesson: ICT guidelines must evolve with technology. An 8-year gap created a massive regulatory blind spot

Recent Digital Trends in Banking(Global)

1. Open Banking — APIs allow third-party developers to build products around bank data (PSD2 in EU)
2. Embedded Finance — Banking services embedded in non-banking apps (e.g., buy-now-pay-later)
3. Digital-Only Banks (Neobanks) — No physical branches (Revolut, N26, bKash evolution)
4. Central Bank Digital Currencies (CBDCs) — Digital versions of national currencies (China's e-CNY, pilot programs globally)
5. Biometric Authentication — Face ID, fingerprint, voice recognition replacing passwords
6. Real-Time Payments — Instant settlement (UPI in India, FPS in UK, bKash in Bangladesh)

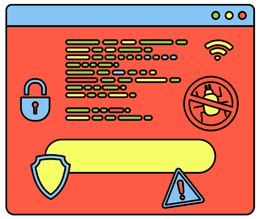
Recent Digital Trends in Banking(Bangladesh)

1. Mobile Financial Services (MFS) dominance — bKash, Nagad, Rocket
2. Agent banking expanding financial inclusion to rural areas
3. Bangladesh Bank's Bangla QR for interoperable payments
4. National Payment Switch Bangladesh (NPSB) for interbank transactions

ICT Security Threats Banks Facing Today



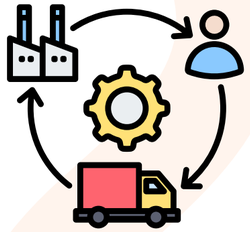
Phishing/Spear Phishing



Ransomware



Business Email Compromise (BEC)



Supply Chain Attacks



Insider Threats



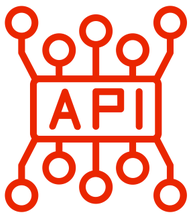
DDoS Attacks



SIM Swapping



Deepfake Fraud



API Vulnerabilities



Zero-Day Exploits

Notable Banking Security Breaches (Global)

1

JPMorgan Chase Data Breach (2014)

- 76 million households and 7 million businesses affected
- Attackers gained access through a single unpatched server
- Stolen: names, addresses, phone numbers, email addresses
- No financial accounts compromised but massive reputational damage
- Lesson: A single unpatched vulnerability can expose the entire customer base

2

SWIFT Banking Fraud — Global (2015–2016)

- Attackers compromised SWIFT messaging systems at multiple banks
- Used malware to send fraudulent international transfer instructions
- Affected banks in Bangladesh, Ecuador, Vietnam, Taiwan
- Total attempted theft: over $1 billion globally
- Lesson: Interbank messaging systems are prime targets; authentication must be multi-layered

3

Equifax Breach (2017)

- 147 million consumers' financial data exposed
- Caused by an unpatched Apache Struts vulnerability
- Resulted in $575 million FTC settlement
- Lesson: Third-party software patches are as critical as internal patching

Case Study 1: The Bangladesh Bank Cyber Heist (2016)

Strategic Patience

Malware installed on Bangladesh Bank's systems months in advance.

Attackers silently monitored operations to learn the internal SWIFT process.

Executed on a Thursday night to exploit the start of the Bangladesh weekend, maximizing response delay.

The Billion-Dollar Transfer

Compromised SWIFT Terminals

↓

35 Fraudulent SWIFT Transfer Requests

↓

Target Amount: Nearly $1 Billion

↓

Destination: Federal Reserve Bank of New York

The Financial Fallout

$81 Million

- Transferred to accounts in the Philippines
- Routed via Rizal Commercial Banking Corp (RCBC)
- Quickly converted to untraceable casino chips

$850 Million

- Blocked due to a single spelling error triggering a routine check

The Typo: The attackers misspelled foundation as fandation, halting the remaining transfers.

CASE STUDY 2

Carbanak / FIN7 Banking Malware Attack

Attack Scale

$1+ Billion
Stolen

100+ Banks
Targeted

30+ Countries
Impacted

How The Attack Worked

- Spear Phishing Emails
- Malicious Word Attachments
- Attackers Lived Inside Networks For 2 to 4 Months
- Remote Control Of Bank Systems
- ATM Jackpotting And **Fraudulent Transfers**

Key Security Lessons

- Employee Phishing Awareness Is Critical
- Email Attachments Must Be Scanned
- Monitor Lateral Movement Inside Networks
- Use AI Based Anomaly Detection

GLOBAL EVOLUTION

United States

2015
FFIEC introduced to hamellate and and security guidelinoss security

2023 Updated to a Cybersecurity Maturity Model

Focus Areas

- AI governance & cloud security
- Third-party risk management
- Cyber incident management

Key Highlights

- Maturity levels across 5 domains
- Cyber Risk Management & Threat
- Intelligence

Key Concept

Banks must demonstrate cybersecurity maturity across all 5 domains

European Union

2023
DORA introduced

2025 Full compliance required

Focus Areas

- ICT risk management
- Incident reporting (within 4 hours)
- Digital operational resilience testing

Key Highlights

- Mandatory for all financial entities
- Register of critical third-party ICT providers
- Considered the current global gold standard

Key Concept

Full compliance required — covers banks, insurance, and investment firms

United Kingdom

2021
Operational Resilience Policy introduced

2025 Full compliance deadline

Focus Areas

- Identifying important business services
- Setting impact tolerances
- Ensuring continuity during disruptions

Key Highlights

- Covers all regulated financial institutions
- Applies to operational disruptions of any kindutions
- Enforced by PRA and FCAes to operational disruptions of any kindutions

Key Concept

Banks must maintain important business services within impact tolerances during disruptions

EVOLUTION ACROSS ALL FRAMEWORKS

	FFIEC (US)	DORA (EU)	BB v4 (2023)	BB v3 (2015)
AI/ML Governance	✓	✓	✓	✗
Operational Resilience	✓	✓	○	✗
Third-Party Registry	✓	✓	○	✗
Cyber Maturity Assessment	✓	✓	✗	✗
Incident Reporting Timeline	72 hrs	4 hrs	Not specified	✗

v4 is a massive improvement, but lags behind DORA and FFIEC in strict enforcement timelines and maturity modeling.

GAPS IN THE SYSTEM

Incident Timelines
(No strict 4-hour rule)

Cyber Maturity
(No measurement framework)

Cloud Security
(Lacks detailed controls)

Zero Trust
(Architecture unaddressed)

Quantum Threats
(No post-quantum prep)

IoT Security
(No dedicated controls)

Social Media
(Risk unaddressed)

Deepfakes
(Synthetic identity fraud missing)

CBDC Security
(Digital Taka guidelines pending)

Penetration Testing
(Frequency undefined)

KEY TAKEAWAYS

1. **Security is a People Problem:** Training (Ch 13) is the absolute foundation.
2. **Tech Outpaces Rules:** The 8-year v3/v4 gap exposed banks to AI threats.
3. **No One is Immune:** The Central Bank Heist proved universal vulnerability.
4. **Exponential Risk:** AI, ML, and Blockchain require entirely new paradigms.
5. **Global Gaps Remain:** Bangladesh must keep pace with DORA and FFIEC.
6. **Customer Education is Mandatory:** In mobile-first economies, uninformed customers are the primary vulnerability.

SAMPLE EXAMINATION QUESTION

Short Questions:

1. What are the five objectives of a customer awareness program as stated in Chapter 11 (v3) of the Bangladesh Bank ICT Security Guideline?
2. List any four training delivery methods mentioned in Chapter 13.2 of the v4 Guideline.3.
3. What is "Training of Trainers" (ToT)? Why is it required under v4?
4. Name three international certification bodies mentioned in Chapter 13.4 (v4) for IT personnel training.
5. What are the main differences between Chapter 11 of v3 and Chapter 13.6 of v4 regarding customer education?

Analytical Questions:

6. Compare the security risk management requirements for AI systems versus ML systems under Chapter 14 of v4. What are the key differences in their threat models?
7. Explain why the Bangladesh Bank Cyber Heist of 2016 could be considered a failure of multiple chapters of the v3 ICT Security Guideline simultaneously.

SAMPLE EXAMINATION QUESTION

Application-Based:

8. A bank is implementing an AI-powered loan approval system. Using Chapter 14.1 of the v4 Guideline, identify at least five security controls the bank must implement.
9. A bank's RPA bot is processing bulk fund transfers and has been given administrator-level access to all banking modules for convenience. Identify the specific v4 guideline violations and explain what should be done instead.
10. Bangladesh Bank is considering adopting blockchain for interbank settlement. Using Chapter 14.5, outline the seven mandatory steps the regulator must guide banks through.

Critical Thinking:

11. The EU's DORA requires financial institutions to report significant ICT incidents within 4 hours. The Bangladesh Bank ICT Guideline v4 says incidents should be reported "as soon as possible." Critically analyze this difference and argue whether Bangladesh Bank should adopt a specific timeline.
12. Given that the Bangladesh Bank Heist involved the SWIFT messaging system and occurred before v4 was published, assess whether Chapter 14 of v4 adequately addresses the risks posed by critical financial messaging infrastructure.

Thank You